

第14章

VPN 技术

14.1

VPN 概述

随着电子商务和电子政务应用的日益普及,越来越多的企业欲把处于世界各地的分支机构、供应商和合作伙伴通过 Internet 连接在一起,以加强总部与各分支机构的联系,提高企业与供应商和合作伙伴之间的信息交换速度;使移动办公人员能在出差时访问总部的网络进行信息交换。为了实现 LAN-to-LAN 的互连,传统的企业组网方案是租用电信 DDN 专线或帧中继电路以组成企业的专用网络,但这种方案成本太高,企业无法承受。对于移动用户而言,出差时只能通过拨号线路访问所属企业的网络。随着全球化步伐的加快和公司业务的增长,移动办公人员会越来越多,公司的客户关系也越来越庞大,这样的方案必然导致昂贵的线路租用费和长途电话费。在这种背景下,人们便想到是否可以使用无处不在的 Internet 来构建企业自己的专用网络。这种需求就导致了虚拟专网(Virtual Private Network, VPN)概念的出现。

采用 VPN 技术组网,企业可以以一种相对便宜的月付费方式上网。然而,Internet 是一个共享的公共网络,因此不能保证数据在两点之间传递时不被他人窃取。要想安全地将两个企业子网连在一起,或者确保移动办公人员能安全地远程访问公司内部秘密资源,就必须保证 Internet 上传输数据的安全,并对远程访问的移动用户进行身份认证。

14.1.1 VPN 的概念

所谓虚拟专网,是指将物理上分布在不同地点的网络通过公用网络连接而构成逻辑上的虚拟子网。它采用认证、访问控制、机密性、数据完整性等安全机制在公用网络上构建专用网络,使得数据通过安全的“加密管道”在公用网络中传播。这里的公用网通常指 Internet。

VPN 技术实现了内部网信息在公用信息网中的传输,就如同在茫茫的广域网中为用户拉出一条专线。对于用户来讲,公用网络起到了“虚拟”的效果,虽然他们身处世界的不同地方,但感觉仿佛是在同一个局域网里工作。VPN 对每个使用者来说也是“专用”的。也就是说,VPN 根据使用者的身份和权限,直接将其接入 VPN,非法的用户不能接入 VPN 并使用其服务。

14.1.2 VPN 的特点

在实际应用中,用户需要什么样的 VPN 呢?好的 VPN 应具备以下几个特点。

1. 费用低

由于企业使用 Internet 进行数据传输, 相对于租用专线来说, 费用极为低廉, 所以 VPN 的出现使企业通过 Internet 既安全又经济地传输机密信息成为可能。

2. 安全保障

虽然实现 VPN 的技术和方式很多, 但所有的 VPN 均应保证通过公用网络平台所传输数据的专用性和安全性。在非面向连接的公用 IP 网络上建立一个逻辑的、点对点的连接, 称为建立了一个隧道。经由隧道传输的数据采用加密技术进行加密, 以保证数据仅被指定的发送者和接收者知道, 从而保证了数据的专用性和安全性。

3. 服务质量保证 (QoS)

VPN 应当能够为企业数据提供不同等级的服务质量保证。不同的用户和业务对服务质量 (QoS) 保证的要求差别较大。例如, 对于移动办公用户来说, 网络能提供广泛的连接和覆盖性是保证 VPN 服务质量的一个主要因素; 而对于拥有众多分支机构的专线 VPN, 则要求网络能提供良好的稳定性; 其他一些应用 (如视频等) 则对网络提出了更明确的要求, 如网络时延及误码率等。所有网络应用均要求 VPN 根据需要提供不同等级的服务质量。

在网络优化方面, 构建 VPN 的另一重要需求是充分、有效地利用有限的广域网资源, 为重要数据提供可靠的带宽。广域网流量的不确定性使其带宽的利用率很低, 在流量高峰时可能会引起网络阻塞, 产生网络瓶颈, 使实时性要求高的数据得不到及时发送; 而在流量低谷时又造成大量的网络带宽闲置。QoS 通过流量预测与流量控制策略, 可以按照优先级分配带宽资源, 实现带宽管理, 使各类数据能够被合理地有序发送, 并预防阻塞的发生。

4. 可扩充性和灵活性

VPN 必须能够支持通过内域网 (Intranet) 和外联网 (Extranet) 的任何类型的数据流、方便增加新的节点、支持多种类型的传输媒介, 可以满足同时传输语音、图像和数据对高质量传输及带宽增加的需求。

5. 可管理性

从用户角度和运营商角度来看, 对 VPN 进行管理和维护应该非常方便。在 VPN 管理方面, VPN 要求企业将其网络管理功能从局域网无缝地延伸到公用网, 甚至是客户和合作伙伴处。虽然可以将一些次要的网络管理任务交给服务提供商去完成, 企业自己仍需要完成许多网络管理任务。所以, 一个完善的 VPN 管理系统是必不可少的。VPN 管理系统的设计目标为: 降低网络风险, 在设计上应具有高扩展性、经济性和高可靠性。事实上, VPN 管理系统的主要功能包括安全管理、设备管理、配置管理、访问控制列表管理、QoS 管理等内容。

14.1.3 VPN 的分类

根据 VPN 组网方式、连接方式、访问方式、隧道协议和工作层次 (OSI 模型或 TCP/IP

模型)的不同,VPN可以有多种分类方法。根据访问方式的不同,VPN可分为两种类型:一种是移动用户远程访问VPN连接;另一种是网关-网关VPN连接。这两种VPN将在本节中做简单介绍。根据隧道协议及工作层次分类的VPN,将在14.3节中详细阐述。

1. 远程访问VPN

移动用户远程访问VPN连接,由远程访问的客户机提出连接请求,VPN服务器提供对VPN服务器或整个网络资源的访问服务。在此连接中,链路上第一个数据包总是由远程访问客户机发出。远程访问客户机先向VPN服务器提供自己的身份,之后作为双向认证的第二步,VPN服务器也向客户机提供自己的身份。

2. 网关-网关VPN

网关-网关VPN连接,由呼叫网关提出连接请求,另一端的VPN网关做出响应。在这种方式中,链路的两端分别是专用网络的两个不同部分,来自呼叫网关的数据包通常并非源自该网关本身,而是来自其内网的子网主机。呼叫网关首先向应答网关提供自己的身份,作为双向认证的第二步,应答网关也应向呼叫网关提供自己的身份。

一个典型VPN的组成如图14-1所示。

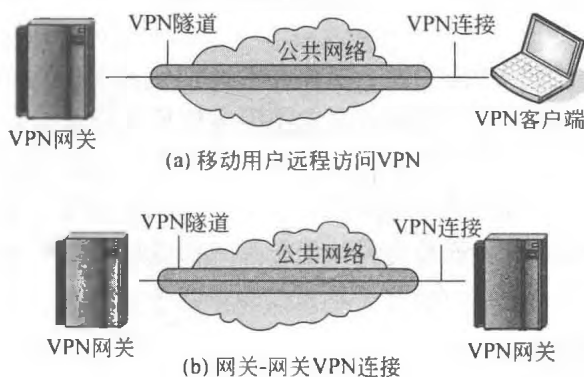


图 14-1 典型 VPN 的组成

14.1.4 VPN 关键技术

VPN 采用多种技术来保证安全,这些技术包括隧道技术(Tunneling)、加/解密(Encryption & Decryption)、密钥管理(Key Management)、使用者与设备身份认证(Authentication)、访问控制(Access Control)等。

1. 隧道技术

隧道技术是VPN的基本技术,它在公用网上建立一条数据通道(隧道),让数据包通过这条隧道进行传输。隧道是由隧道协议构建的,常用的有第2、3层隧道协议。第2层隧道协议首先把各种网络协议封装到PPP中,再把整个数据包装入隧道协议中。这种双层封装方法形成的数据包靠第2层协议进行传输。第2层隧道协议有L2F、PPTP、L2TP等。L2TP是由PPTP与L2F融合而成,目前它已经成为IETF的标准。

第3层隧道协议把各种网络协议直接装入隧道协议中,形成的数据包依靠第3层协

议进行传输。第 3 层隧道协议有 GRE, VTP、IPSec 等。IPSec (IP Security) 是由一组 RFC 文档描述的安全协议, 它定义了一个系统来选择 VPN 所用的密码算法, 确定服务所使用密钥等服务, 从而在 IP 层提供安全保障。

2. 加/解密技术

在 VPN 应用中, 加/解密技术是将认证信息、通信数据等由明文转换为密文的相关技术, 其可靠性主要取决于加/解密的算法及强度, 这部分内容在密码学课程中有详细介绍。

3. 密钥管理技术

密钥管理的主要任务是保证密钥在公用数据网上安全地传递而不被窃取。现行的密钥管理技术又分为 SKIP 与 ISAKMP/OAKLEY 两种。SKIP 主要利用 Diffie-Hellman 密钥分配协议, 使通信双方建立起共享密钥。在 ISAKMP 中, 双方都持有两把密钥, 即公钥/私钥对, 通过执行相应的密钥交换协议而建立共享密钥。

4. 身份认证技术

在正式的隧道连接开始之前, VPN 需要确认用户的身份, 以便系统进一步实施资源访问控制或对用户授权。

5. 访问控制

访问控制决定了谁能够访问系统、能访问系统的何种资源及如何使用这些资源。采取适当的访问控制措施能够阻止未经允许的用户有意或无意地获取数据, 或者非法访问系统资源等。

14.2

隧道协议与 VPN

通常, 隧道是指为修建公路或铁路, 挖通山麓而形成的通道。VPN 的隧道概念指的是通过一个公用网络 (通常是 Internet) 建立的一条穿过公用网络的安全的、逻辑上的隧道。在隧道中, 数据包被重新封装发送。所谓封装, 就是在原 IP 分组上添加新的报头, 就好像将数据包装进信封一样。因此, 封装操作也称为 IP 封装化。总部和分公司之间交流信息时所传递的数据, 经过 VPN 设备封装后通过 Internet 自动发往对方的 VPN 设备。这种在 VPN 设备之间建立的封装化数据的 IP 通信路径在逻辑上被称为隧道。发端 VPN 在对 IP 数据包前加新报头封装后, 将封装后的数据包通过 Internet 发送给收端 VPN。收端 VPN 在接收到封装数据包后, 将隧道标头删除, 再发给目标主机。数据包在隧道中的封装及发送过程如图 14-2 所示。

隧道封装和加密方式多种多样。一般来说, 只对数据加密的通信路径不能称为隧道。在一个数据包上再添加一个报头才称做封装化。是否对封装的数据包加密取决于隧道协议。例如, IPSec 的 ESP 是加密封装化协议, 而 L2TP 则不对分组加密, 保持原样进行封装。

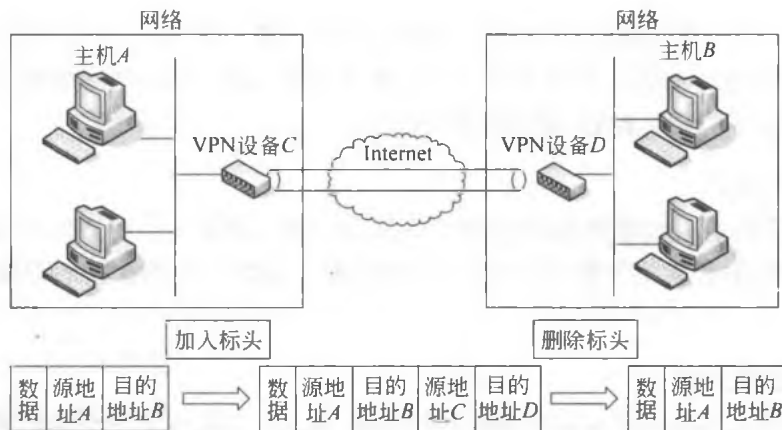


图 14-2 数据包在隧道中的封装及发送过程

现有的封装协议主要包括两类：一类是第2层的隧道协议，由于隧道协议是对数据链路层的数据包进行封装（即OSI开放系统互连模型中第2层的数据包），所以称其为第2层隧道协议，这类协议包括PPTP、L2TP、L2F等，主要用于构建远程访问VPN；另一类是第3层隧道协议，如IPSec、GRE等，它们把网络层的各种协议数据包直接封装到隧道协议中进行传输，由于被封装的是第3层的网络协议数据包，所以称为第3层隧道协议，它主要用于构建LAN-to-LAN型的VPN。

14.2.1 第2层隧道协议

第2层隧道协议主要有3个：一个是由微软、Asend、3COM等公司支持的点对点隧道协议（Point to Point Tunneling Protocol, PPTP）；另一个是Cisco、Nortel等公司支持的第2层转发（Layer 2 Forwarding, L2F）协议；第三个是由IETF起草，微软、Cisco、3COM等公司共同制定的第2层隧道协议（Layer 2 Tunneling Protocol, L2TP），该协议结合了以上两个协议的优点。下面对这3个协议进行简要介绍。

1. PPTP

PPTP是一种用于让远程用户拨号连接到本地ISP、通过Internet安全远程访问公司网络资源的新技术。PPTP对PPP本身并没有做任何修改，只是使用PPP拨号连接，然后获取这些PPP包，并把它们封装进GRE头中。PPTP使用PPP的PAP或CHAP（MS-CHAP）进行认证，另外也支持Microsoft公司的点到点加密技术（MPPE）。PPTP支持的是一种Client-LAN型隧道的VPN实现。

PPTP具有两种不同的工作模式，即被动模式和主动模式。被动模式的PPTP会话通过一个一般位于ISP处的前端处理器发起，在客户端不需要安装任何与PPTP有关的软件。在拨号连接到ISP的过程中，ISP为用户提供所有相应的服务和帮助。被动方式的优点是降低了对客户的要求，缺点是限制了客户对Internet其他部分的访问。

主动方式是由客户建立一个与网络另外一端服务器直接连接的PPTP隧道，这种方式不需要ISP的参与，不再需要位于ISP处的前端处理器，ISP只提供透明的传输通道。这种方式的优点是客户拥有对PPTP的绝对控制；缺点是对用户的要求较高，并需要在

客户端安装支持 PPTP 的相应软件。

通过 PPTP, 远程用户经由 Internet 访问企业的网络和应用, 而不再需要直接拨号至企业的网络。这样大大地减少了建立和维护专用远程线路的费用, 同时也为企业提供了充分的安全保证。另外, PPTP 还在 IP 网络中支持 IP 协议。PPTP “隧道” 将 IP、IPX、APPLE-TALK 等协议封装在 IP 包中, 使用户能够运行基于特定网络协议的应用程序。同时, “隧道” 采用现有的安全检测和认证策略, 还允许管理员和用户对数据进行加密, 使数据更加安全。PPTP 还提供灵活的 IP 地址管理。如果企业专用网络使用未经注册的 IP 地址, 那么 PNS 将把此地址和企业专用地址联系起来。

PPTP 是为中小企业提供的 VPN 解决方案, 但此协议在实现上存在着重大安全隐患。有研究表明其安全性甚至比 PPP 还要弱, 因此不适用于对安全性需求很高的通信。如果条件允许, 用户最好选择完全能够替代 PPTP 的下一代二层协议 L2TP。

2. L2F

L2F 协议由 Cisco 公司在 1998 年 5 月提交给 IETF, RFC2341 对 L2F 有详细的阐述。L2F 可以在多种介质 (如 AMT、帧中继、IP 网) 上建立多协议的安全虚拟专用网, 它将链路层的协议 (如 HDLC, PPP, ASYNC 等) 封装起来传送。因此, 网络的链路层完全独立于用户的链路层协议。L2F 远程用户能够通过任何拨号方式接入公共 IP 网络。首先, 按常规方式拨号到 ISP 的接入服务器 (NAS), 建立 PPP 连接; 然后, NAS 根据用户名等信息, 发起第二重连接, 呼叫用户网络的服务器。在这种方式下, 隧道的建立和配置对用户是完全透明的。L2F 允许拨号接入服务器发送 PPP 帧, 并通过 WAN 连接到达 L2F 服务器。L2F 服务器将包解封装后, 把远程用户接入到公司自己的网络中。

3. L2TP

L2TP 的前身是 Microsoft 公司的点到点隧道协议 (PPTP) 和 Cisco 公司的二层转发 (L2F) 协议。PPTP 是为中小企业提供的 VPN 解决方案, 但此协议在安全性上存在着重大隐患。L2F 协议是一种安全通信隧道协议, 它的主要缺陷是没有把标准加密算法定义在内, 因此它已成为过时的隧道协议。IETF 的开放标准 L2TP 结合了 PPTP 和 L2F 协议的优点, 特别适合组建远程接入方式的 VPN, 因此已经成为事实上的工业标准。

远程拨号的用户通过本地 PSTN、ISDN 或 PLMN 拨号, 利用 ISP 提供的 VPDN 特服号, 接入 ISP 在当地的接入服务器 (NAS)。NAS 通过当地的 VPDN 管理系统 (如认证系统) 对用户身份进行认证, 并获得用户对应的企业安全网关 (CPE) 的隧道属性 (如企业网关的 IP 地址等)。NAS 根据获得的这些信息, 采用适当的隧道协议封装上层协议, 建立一个位于 NAS 和 LNS (本地网络服务器) 之间的虚拟专网。

第 2 层隧道协议具有简单易行的优点, 但是它们的可扩展性都不好。更重要的是, 它们没有提供内在的安全机制, 不能支持企业和企业的外部客户及供应商之间会话的保密性需求。因此, 当企业欲将其内部网与外部客户及供应商网络相连时, 第 2 层隧道协议不支持构建企业外域网 (Extranet)。Extranet 需要对隧道进行加密并需要相应的密钥管理机制。

14.2.2 第3层隧道协议

第3层隧道协议主要包括 IPSec、GRE（Generic Routing Encapsulation）和多协议标记交换（Multiprotocol Label Switching, MPLS）技术。由这3种协议和技术构建的 VPN 分别称为 IPSec VPN、GRE VPN 和 MPLS VPN。

下面分别对这3种VPN协议和技术做简要介绍。

1. IPSec

IPSec 是专为 IP 设计提供安全服务的一种协议（其实是一种协议族）。IPSec 可有效保护 IP 数据报的安全，具体保护形式包括数据源验证、无连接数据的完整性验证、数据内容的机密性保护、抗重放保护等。

IPSec 主要由 AH（认证头）、ESP（封装安全载荷）、IKE（Internet 密钥交换）3 个协议组成。IPSec 协议既能用于点对点连接型 VPN，也可以用于远程访问型 VPN。

在 14.3 节中，将对 IPSec VPN 进行深入讨论。

2. GRE

通用路由协议封装（GRE）是由 Cisco 和 NetSmiths 等公司于 1994 年提交给 IETF 的协议，标号为 RFC1701 和 RFC1702。目前多数厂商的网络设备均支持 GRE 隧道协议。

GRE 规定了如何用一种网络协议去封装另一种网络协议的方法。GRE 隧道由两端的源 IP 和目的 IP 来定义，允许用户使用 IP 包封装 IP、IPX、AppleTalk 包，并支持全部路由协议（如 RIP2、OSPF 等）。通过 GRE，用户可以利用公共 IP 网络连接 IPX 网络、AppleTalk 网络，还可以使用保留地址进行网络互连，或者对公网隐藏企业网的 IP 地址。GRE 只提供数据包的封装，并没有采用加密功能来防止网络侦听和攻击，所以在实际环境中经常与 IPSec 一起使用，由 IPSec 提供用户数据的加密，从而给用户提供更好的安全性。GRE 的实施策略及网络结构与 IPSec 非常相似，只要网络边缘的接入设备支持 GRE 协议即可。

3. MPLS

MPLS 属于第3层交换技术，引入了基于标记的机制。它把选路和转发分开，用标签来规定一个分组通过网络的路径。MPLS 网络由核心部分的标签交换路由器（LSR）和边缘部分的标签边缘路由器（LER）组成。

MPLS 为每个 IP 包加上一个固定长度的标签，并根据标签值转发数据包。MPLS 实际上就是一种隧道技术，所以使用它来建立 VPN 隧道十分容易。同时，MPLS 是一种完备的网络技术，可以用来建立 VPN 成员之间简单而高效的 VPN。MPLS VPN 适用于实现对服务质量、服务等级的划分及网络资源的利用率、网络的可靠性有较高要求的 VPN 业务。

CE 路由器用于将一个用户站点接入服务提供者网络的用户边缘路由器。CE 路由器不使用 MPLS，它可以只是一台 IP 路由器。CE 不必支持任何 VPN 的特定路由协议或信令。

PE 路由器是与用户 CE 路由器相连的服务提供者边缘路由器。PE 实际上就是 MPLS

中的边缘标记交换路由器（LER），能够支持 BGP、一种或几种 IGP 路由协议及 MPLS 协议，能够执行 IP 包检查、协议转换等功能。

用户站点指这样一组网络或子网，它们是用户网络的一部分，并且通过一条或多条 PE/CE 链路接至 VPN。一组共享相同路由信息的站点就构成了 VPN。一个站点可以同时位于不同的几个 VPN 之中。

从 MPLS VPN 网络的结构可以看到，与前几种 VPN 技术不同，MPLS VPN 网络中的主角虽然仍然是边缘路由器（此时是 MPLS 网络的边缘 LSR），但是它需要公共 IP 网内部的所有相关路由都能够支持 MPLS，所以这种技术对网络有特殊的要求。

VPN 有多种类型，本书将主要讨论 IPSec VPN、PPTP VPN、SSL VPN 和 MPLS VPN。SSL VPN 也称做传输层安全（Transport Layer Security，TLS）协议 VPN。之所以讨论这些 VPN，是因为它们的应用最为广泛。由于 PPTP VPN 和 MPLS VPN 的安全性相对较低，所以这里将重点讨论 IPSec VPN 和 TLS VPN，而对 PPTP VPN 和 MPLS VPN 原理只做简要的阐述。

14.3 IPSec VPN

14.3.1 IPSec 协议概述

IPSec 在 IPv6 的制定过程中产生，用于提供 IP 层的安全性。由于所有支持 TCP/IP 的主机在进行通信时都要经过 IP 层的处理，所以提供了 IP 层的安全性就相当于为整个网络提供了安全通信的基础。鉴于 IPv4 的应用仍然很广泛，所以后来在 IPSec 的制定中也增添了对 IPv4 的支持。

IPSec 标准最初由 IETF 于 1995 年制定，但由于其中存在一些未解决的问题，从 1997 年开始 IETF 又开展了新一轮的 IPSec 标准的制定工作，1998 年 11 月，主要协议已经基本制定完成。由于这组新的协议仍然存在一些问题，IETF 将来还会对其进行修订。

IPSec 所涉及的一系列 RFC 标准文档如下。

- RFC2401: IPSec 系统结构。
- RFC2402: 认证首部协议（AH）。
- RFC2406: 封装净荷安全协议（ESP）。
- RFC2408: Internet 安全联盟和密钥管理协议（ISAKMP）。
- RFC2409: Internet 密钥交换协议（IKE）。
- RFC2764: 基本框架文档。
- RFC2631: Diffie-Hellman 密钥协商方案。
- SKEME。

在后面的讨论中，重点将放在 ESP 的保密性和完整性方面。

IPSec 协议由 AH 和 ESP 提供了两种工作模式（注意，切勿将它们和下文要讨论的 ISAKMP 模式相混淆），如图 14-3 所示。这两个协议可以组合起来使用，也可以单独使

用 AH 或 ESP，还可以同时使用 AH 和 ESP。IPSec 的功能和模式如表 14-1 所示。



图 14-3 IPSec 协议的构成

AH、ESP 或 AH+ESP 既可以在隧道模式中使用，又可以在传输模式中使用。隧道模式在两个 IP 子网之间建立一个安全通道，允许每个子网中的所有主机用户访问对方子网中的所有服务和主机。传输模式在两个主机之间以端对端的方法提供安全通道，并且在整个通信路径的建立和数据的传递过程中采用了身份认证、数据保密性和数据完整性等安全保护措施。

表 14-1 IPSec 的功能和模式

功能/模式	认证首部（AH）	封装安全负荷（ESP）	ESP+AH
访问控制	Yes	Yes	Yes
认证	Yes	—	Yes
消息完整性	Yes	—	Yes
重放保护	Yes	Yes	Yes
机密性	—	Yes	Yes

14.3.2 IPSec 的工作原理

IPSec 的工作原理类似于包过滤防火墙，可以把它看做是包过滤防火墙的一种扩展。我们知道，防火墙在接收到一个 IP 数据包时，它就在规则表中查找是否有与数据包的头部相匹配的规则。当找到一个相匹配的规则时，包过滤防火墙就按照该规则的要求对接收到的 IP 数据包进行处理：丢弃或转发。

IPSec 通过查询安全策略数据库（Security Policy Database，SPD）决定如何对接收到的 IP 数据包进行处理。但是 IPSec 与包过滤防火墙不同，它对 IP 数据包的处理方法除了丢弃和直接转发（绕过 IPSec）外，还可以对数据包进行 IPSec 处理。正是这种新增添的处理方法，使 VPN 提供了比包过滤防火墙更高的安全性。

进行 IPSec 处理意味着对 IP 数据包进行加密和认证。包过滤防火墙只能控制来自或去往某个站点的 IP 数据包的通过，即它可以拒绝来自某个外部站点的 IP 数据包访问内

部网络资源，也可以拒绝某个内部网络用户访问某些外部网站。但是包过滤防火墙不能保证自内部网络发出的数据包不被截取，也不能保证进入内部网络的数据包未经篡改。只有在对 IP 数据包实施了加密和认证后，才能保证在公用网络上传输数据的机密性、认证性和完整性。

IPSec 既可以对 IP 数据包只进行加密或认证，也可以同时实施加密和认证。但无论是进行加密还是进行认证，IPSec 都有两种工作模式：一种是传输模式；另一种是隧道模式。

采用传输模式时，IPSec 只对 IP 数据包的净荷进行加密或认证。此时，封装数据包继续使用原 IP 头部，只对 IP 头部的部分域进行修改，而 IPSec 协议头部插入到原 IP 头部和传输层头部之间。IPSec 传输模式如图 14-4 和图 14-5 所示。

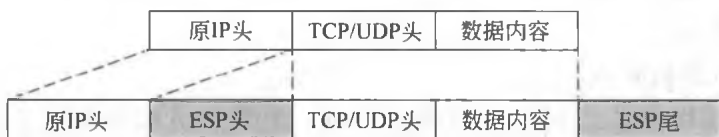


图 14-4 传输模式的 ESP 封装示意图

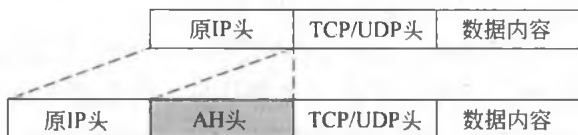


图 14-5 传输模式的 AH 封装示意图

采用隧道模式时，IPSec 对整个 IP 数据包进行加密或认证。此时，需要产生一个新的 IP 头，IPSec 头被放在新产生的 IP 头和原 IP 数据包之间，从而组成一个新的 IP 头。IPSec 隧道模式如图 14-6 和图 14-7 所示。

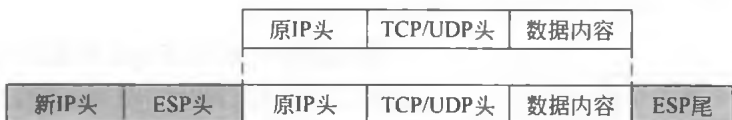


图 14-6 IPSec 隧道模式的 ESP 封装示意图

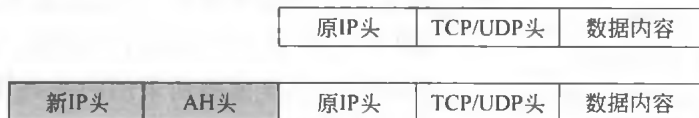


图 14-7 IPSec 隧道模式的 AH 封装示意图

14.3.3 IPSec 中的主要协议

前面已经提到 IPSec 的主要功能为加密和认证。为了进行加密和认证，IPSec 还需要有密钥的管理和交换功能，以便为加密和认证提供所需要的密钥并对密钥的使用进行管理。以上 3 方面的工作分别由 AH、ESP 和 IKE 3 个协议来实现。为了介绍这 3 个协议，需要先引入一个非常重要的术语——安全关联（Security Association，SA）。所谓安全关

联，是指安全服务与它服务的载体之间的一个“连接”，文中还会详细讨论 SA。AH 和 ESP 的实现都需要 SA 的支持，而 IKE 的主要功能就是建立和维护 SA。

如果要用 IPSec 建立一条安全的传输通路，通信双方需要事先协商好将要采用的安全策略，包括使用的加密算法、密钥、密钥的生存期等。当双方协商好使用的安全策略后，通常就说双方建立了一个 SA。给定了一个 SA，就确定了 IPSec 要执行的处理，如加密、认证等。

1. AH（Authentication Header）

RFC2402 的作者设计了 AH 协议来防御中间人攻击。RFC2402 对 AH 协议进行了极为详细的定义，将 AH 服务定义如下：

- 非连接的数据完整性校验。
- 数据源点认证。
- 可选的抗重放服务。

AH 有两种实现方式：传输方式和隧道方式，如图 14-5 和图 14-7 所示。当 AH 以传输方式实现时，它主要提供对高层协议的保护，因为高层的数据不进行加密。当 AH 以隧道方式实现时，协议被应用于通过隧道的 IP 数据包。

AH 只涉及认证，不涉及加密。AH 虽然在功能上与 ESP 有重复之处，但 AH 除了可以对 IP 的净荷进行认证外，还可以对 IP 头实施认证，而 ESP 的认证功能主要是面向 IP 的净荷。为了提供最基本的功能并保证互操作性，AH 必须提供对 HMAC SHA 和 HMAC MD-5（HMAC 是由杂凑函数 SHA 和 MD-5 构造的消息认证码）的支持。

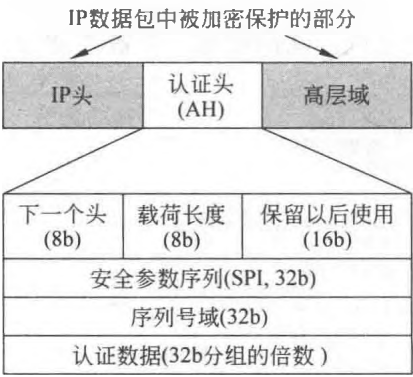


图 14-8 认证头的结构及其在 IP 数据包中的位置

AH 的长度是可变的，但必须是 32b 数据报长度的倍数。AH 域被细分为几个子域，其中包含为 IP 数据包提供密码保护所需的数据，如图 14-8 所示。

数据源点认证是 IPSec 的强制性服务，它实际上提供了对源点身份数据的完整性保护。提供该保护所需的数据包含在 AH 的两个子域中，一个子域称为“安全参数索引”（Security Parameters Index, SPI），包含长 32b 的某个任意值，用于唯一标识该 IP 数据包认证服务所采用的密码算法；另一个子域称为“认证数据”，包含消息发送方为接收方生成的认证数据，用于接收方进行数据完整性验证，因此

这部分数据也被称为完整性校验值（Integrity Check Value, ICV）。该 IP 数据包的接收方能够使用密钥和 SPI 所标识的算法重新生成“认证数据”，然后将其与接收到的“认证数据”相比较，从而完成 ICV 校验。

AH 还有一个“序列号”子域，用来抵御 IP 数据包重放攻击。AH 的其他子域（包括“下一个头”、“载荷长度”和“保留以后使用”）都没有安全方面的意义，因此这里不对它们进行讨论。

2. ESP

ESP (Encapsulating Security Payload) 协议主要用于对 IP 数据包进行加密, 此外也对认证提供某种程度的支持。ESP 独立于具体的加密算法, 几乎可以支持各种对称密钥加密算法, 如 DES、TripleDES 和 RC5 等。为了保证各种 IPSec 实现之间的互操作性, 目前要求 ESP 必须支持 56b 密钥长度的 DES 算法。

ESP 的格式如图 14-9 所示。ESP 协议数据单元格式由 3 部分组成, 除了头部、加密数据部分外, 在实施认证时还包含一个可选尾部。头部有两个域: 安全参数索引 (SPI) 和序列号 (Sequence Number) 域。使用 ESP 进行安全通信之前, 通信双方需要先协商好一组将要采用的加密策略, 包括所使用的加密算法、密钥及密钥的有效期等。SPI 用来标识发送方在处理 IP 数据包时使用了哪组加密策略, 当接收方看到了这个标识后就知道如何处理收到的 IP 数据包。“序列号” 用来区分使用同一组加密策略的不同数据包。被加密的数据部分除了包含原 IP 数据包的净荷外, 还包括填充数据。填充数据是为了保证加密数据部分的长度满足分组加密算法的要求。这两部分数据在传输时都要进行加密。“下一个头” (Next Header) 用来标识净荷部分所使用的协议, 它可能是传输层协议 (TCP 或 UDP), 也可能是 IPSec 协议 (ESP 或 AH)。

前面已经提到, IPSec 有两种工作模式, 这意味着 ESP 协议也有两种工作模式: 传输模式 (Transport Mode) 和隧道模式 (Tunnel Mode)。当 ESP 工作于传输模式时, 封装头部采用当前的 IP 头部。在 ESP 工作于隧道模式时, IPSec 将整个 IP 数据包进行加密作为 ESP 净荷, 并在 ESP 头部前增添以网关地址为源地址的新的 IP 头部, 此时 IPSec 可以起到 NAT 的作用。

安全参数索引(SPI, 32b)		
序列号域(32b)		
载荷数据(32b分组的倍数)		
填充数据(0~255B)		
填充长度(8b)		下一个头(8b)
认证数据(32b分组的倍数)		

图 14-9 ESP 的格式

3. IKE

Internet 密钥交换协议 (Internet Key Exchange, IKE) 用于动态建立安全关联 (Security Association, SA)。由 RFC2409 描述的 IKE 属于一种混合型协议。它汲取了 ISAKMP、Oakley 密钥确定协议及 SKEME 的共享密钥更新技术的精华, 从而设计出独一无二的密钥协商和动态密钥更新协议。此外, IKE 还定义了两种密钥交换方式。IKE 使用两个阶段的 ISAKMP: 在第一阶段, 通信各方彼此间建立一个已通过身份验证和安全保护的通道, 即建立 IKE 安全关联; 在第二阶段, 利用这个既定的安全关联为 IPSec 建立安全通道。IKE 图解如图 14-10 所示。

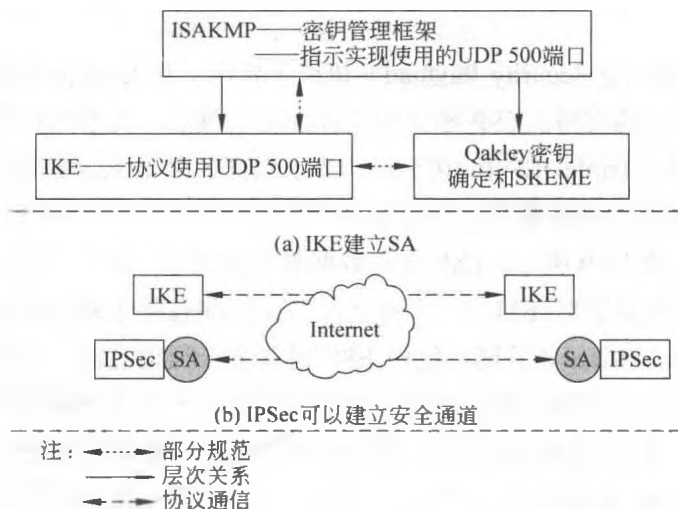


图 14-10 IKE 图解

IKE 定义了两个阶段：阶段 1 交换和阶段 2 交换。Oakley 定义了 3 种模式，分别对应 ISAKMP 的 3 个阶段：快速模式、主模式和野蛮模式。在阶段 1 交换，IKE 采用的是身份保护交换（“主模式”交换），以及根据 ISAKMP 文档制定的“野蛮模式”交换；在阶段 2 交换，IKE 则采用了一种“快速模式”交换。

ISAKMP 通过 IKE 对以下几种密钥交换机制提供支持：

- 预共享密钥（PSK）。
- 公钥基础设施（PKI）。
- IPSec 实体身份的第三方证书。

不难理解，预共享密钥（Preshared Secret Key, PSK）机制实质上是一种简单的口令方法。在 IPSec VPN 网关上预设常量字符串，通信双方据此共享秘密实现相互认证。而采用 PKI 和数字证书的认证方式在第 9 章中已经做了详细介绍。

总之，IKE 可以动态地建立安全关联和共享密钥。IKE 建立安全关联的实现极为复杂。从一方面看，它是 IPSec 协议实现的核心；从另一方面看，它也很可能成为整个系统的瓶颈。进一步优化 IKE 程序和密码算法是实现 IPSec 的核心问题之一。

14.3.4 安全关联

IPSec 的中心概念之一是“安全关联”（Security Association, SA）。从本质上讲，IPSec 可被视为 AH+ESP。当两个网络节点在 IPSec 保护下通信时，它们必须协商一个 SA（用于认证）或两个 SA（分别用于认证和加密），并协商这两个节点间所共享的会话密钥以便它们能够执行加密操作。要在两个安全网关之间建立安全双工通信，需要为每个方向建立一个 SA。在 IPSec 当前的实现方案中，SA 管理机制只定义了单一特性的 SA。这意味着当前的 SA 只能建立点到点的通信。在未来，增强功能将会支持点到点及一点到多点的通信。

每个 SA 的标识由 3 部分组成：

- 安全性参数索引，即 SPI。

- IP 目的地址。
- 安全协议标识, 即 AH 或 ESP。

如前所述, SA 有两种模式, 即传输模式和隧道模式。传输模式下的 SA 是两个主机间的安全关联; 隧道模式下的 SA 只适用于 IP 隧道。如果在两个安全网关之间或一个安全网关和一个主机之间建立安全关联, 那么此 SA 必须使用隧道模式。

当然, 也可以将不同的 SA 组合起来使用, 以提供多层次的安全性或封装能力。当对 SA 进行组合时, 称组合结果为一个 SA 束。此时, IPSec 在对传输数据进行处理时, 也必须进行一系列的安全关联。

14.3.5 IPSec VPN 的构成

VPN 由管理模块、密钥分配和生成模块、身份认证模块、数据加/解密模块、数据分组封装/分解模块和加密函数库等几部分组成。一个 IPSec VPN 的组成如图 14-11 所示。

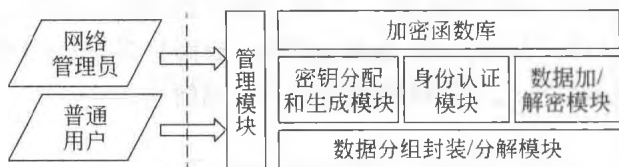


图 14-11 IPSec VPN 的组成

1. 管理模块

管理模块负责整个系统的配置和管理, 它决定了采取何种传输模式, 对哪些 IP 数据包进行加/解密。由于对 IP 数据包进行加密要消耗系统资源、增大网络延迟, 因此对两个安全网关之间的所有 IP 数据包提供 VPN 服务是不现实的。网络管理员可以通过管理模块指定对哪些 IP 数据包进行加密。Intranet 内部用户也可以通过 Telnet 协议传送专用命令, 指定 VPN 系统对自己的 IP 数据包提供加密服务。

2. 密钥分配和生成模块

密钥分配和生成模块负责完成身份认证和数据加密所需的密钥生成和分配。其中, 密钥的生成采取随机生成的方式。各安全网关之间的密钥分配采取手工分配的方式, 或者通过非网络传输的其他安全通信方式完成密钥在各安全网关之间的传送。各安全网关的密钥存储在密钥数据库中, 支持以 IP 地址为关键字的快速查询和获取。

3. 身份认证模块

身份认证模块对 IP 数据包进行消息认证码的运算。整个数字签名的过程如图 14-12 所示。

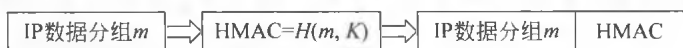


图 14-12 消息认证码计算过程示意图

首先, 发送方对数据 m 和密钥 K 进行杂凑运算 $HMAC=H(m, K)$, 得到消息认证码 HMAC。发送方将 HMAC 附在明文后, 一起传送给接收方。接收方收到数据后, 首先用

共享密钥 K 计算 HMAC', 并将其与接收到的 HMAC 进行比较, 如果二者一致, 则表明数据未被篡改。消息认证码在保证数据完整性的同时也起到了身份认证的作用, 因为只有通信双方有共享密钥的情况下才能得到相同的消息认证码。

4. 数据加/解密模块

数据加/解密模块对 IP 数据包进行加密和解密操作。可选的加密算法有 IDEA 算法和 DES 算法。前者在用软件方式实现时可以获得较快的加密速度。为了进一步提高系统效率, 可以采用专用硬件实现数据的加密和解密, 这时采用 DES 算法能得到较快的加密速度。目前, 随着计算机计算能力的提高, DES 算法已不能满足安全要求。对于安全性要求更高的网络数据, 数据加/解密模块可采用 Triple DES 或 AES 加密算法。

5. 数据分组封装/分解模块

数据分组封装/分解模块实现对 IP 数据分组的安全封装或分解。当从安全网关发送 IP 数据分组时, 数据分组封装/分解模块为 IP 数据分组附加上身份认证头 AH 和安全数据封装头 ESP。当安全网关接收到 IP 数据分组时, 数据分组封装/分解模块对 AH 和 ESP 进行协议分析, 并根据包头信息进行身份验证和数据解密。

6. 加密函数库

加密函数库为上述模块提供统一的加密服务。设计加密函数库的一条基本原则是通过一个统一的函数接口与上述模块进行通信。这样可以根据实际需要, 在挂接加密算法和加密强度不同的函数库时, 无须改动其他模块。

14.3.6 IPSec 的实现

FreeS/WAN 是 Linux 操作系统中包含的 IPSec VPN 实现方案, 在网上可以找到其开放的源代码 (下载网址: www.freeswan.org)。

14.4 SSL/TLS VPN

14.4.1 TLS 协议概述

SSL VPN 也称做传输层安全协议 (TLS) VPN。它起初由 Netscape 公司定义并开发, 后来 IETF 将 SSL 重新更名为 TLS。就设计思想和目标而言, SSL v3 和 TLS v1 是相同的。在本章后面的讨论中, 将使用 TLS 来替代 SSL。

TLS 协议主要用于 HTTPS 协议中。HTTPS 协议将 Web 浏览协议 HTTP 和 TLS 结合在一起。HTTPS 协议是用户进行网上项目申报、网上交易和网上银行操作时常用的一个工具。

TLS 也可以作为构造 VPN 的技术。近年来, TLS VPN 的使用越来越广泛。企业使用 TLS VPN, 可以大大降低通信费用, 并使网络的安全性得到明显提高。与 IPSec VPN 相比, TLS VPN 的最大优点是用户不需要安装和配置客户端软件, 只需要在客户端安装

一个 IE 浏览器即可。相反, IPsec 需要在每台计算机上配置相应的安全策略。虽然 IPsec 的安全性很高, 但这需要技术人员花费很多精力去研究 IPsec 的配置。虽然有一些方法可以自动完成这个过程, 但使用 IPsec VPN 通常会增加管理成本。

由于 TLS 协议允许使用数字签名和证书, 因此 TLS 协议能提供强大的认证功能。在建立 TLS 连接过程中, 客户端和服务端之间要进行多次的信息交互。TLS 协议的连接建立过程如图 14-13 所示。

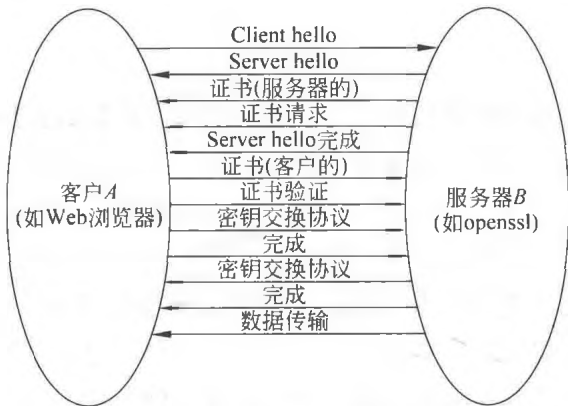


图 14-13 TLS 协议的连接建立过程

与许多客户/服务器方式一样, 客户端通过向服务器发送“Client hello”信息打开连接, 服务器用“Server hello”回答。然后, 服务器要求客户端提供它的数字证书。服务器在完成对客户证书验证后, 就会启动执行密钥交换协议。密钥交换协议的主要任务是:

- 产生一个主密钥。
- 由主密钥产生两个会话密钥: $A \rightarrow B$ 的密钥和 $B \rightarrow A$ 的密钥。
- 由主密钥产生两个消息认证码密钥。

完整的 TLS 协议体系结构如图 14-14 所示。可以看出, TLS 记录协议属于第 3 层协议, 而 TLS 握手协议、TLS 密钥交换协议和 TLS 报警协议均与 HTTP 和 FTP 一样, 属于应用层协议。

TLS 握手协议	TLS 密钥交换协议	TLS 报警协议	HTTP	FTP
TLS 记录协议				
传输控制协议(TCP)				
网间协议(IP)				

图 14-14 完整的 TLS 协议体系结构

14.4.2 TLS VPN 的原理

大多数 TLS VPN 都采用 HTTP 反向代理, 这样它们非常适合于具有 Web 功能的应用, 通过任何 Web 浏览器都可访问。HTTP 反向代理支持其他查询/应答应用, 如企业的

电子邮件及 ERP 和 CRM 等客户/服务器应用。为了访问这些类型的应用，TLS VPN 为远程连接提供了一种简单、经济的方案。它属于即插即用型，不需要任何附加的客户端软件或硬件。一般来讲，TLS VPN 的实现方式是在企业的防火墙后面放置一个 TLS 代理服务器。如果用户欲安全地连接到公司网络，首先要在浏览器上输入一个 URL，该连接请求将被 TLS 代理服务器取得。当该用户通过身份验证后，TLS 代理服务器将提供远程用户与各种不同应用服务器之间的连接。TLS VPN 的实现主要依靠下面 3 种协议的支持。

1. 握手协议

握手协议建立在可靠的传输协议之上，为高层协议提供数据封装、压缩和加密等基本功能的支持。这个协议负责被用于协商客户机和服务器之间会话的加密参数。当一个 TLS 客户机和服务器第一次通信时，它们首先要在选择协议版本上达成一致，选择加密算法和认证方式，并使用公钥技术来生成共享密钥。具体协议流程如下。

(1) TLS 客户机连接至 TLS 服务器，并要求服务器验证客户机的身份。

(2) TLS 服务器通过发送它的数字证书证明其身份。这个交换还可以包括整个证书链，该证书链可以追溯到某个根证书颁发机构。通过检查证书的有效日期并验证数字证书中所包含的可信任 CA 的数字签名来确认 TLS 服务器公钥的真实性。

(3) 服务器发出一个请求，对客户端的证书进行验证。但由于缺乏 PKI 系统的支撑，当今的大多数 TLS 服务器不进行客户端认证。

(4) 协商用于消息加密的加密算法和用于完整性检验的杂凑函数，通常由客户端提供它所支持的所有算法列表，然后由服务器选择最强的密码算法。

(5) 客户机生成一个随机数，并使用服务器的公钥（从服务器证书中获取）对它加密，并将密文发送给 TLS 服务器。

(6) TLS 服务器通过发送另一随机数据做出响应。

(7) 对以上两个随机数进行杂凑函数运算，从而生成会话密钥。

其中，最后 3 步用来生成会话密钥。

2. TLS 记录协议

TLS 记录协议建立在 TCP/IP 之上，用于在实际数据传输开始前通信双方进行身份认证、协商加密算法和交换加密密钥等。发送方将应用消息分割成可管理的数据块，然后与密钥一起进行杂凑运算，生成一个消息认证代码 (Message Authentication Code, MAC)，最后将组合结果进行加密并传输。接收方接收数据并解密，校验 MAC，并对分段的消息进行重新组合，把整个消息提供给应用程序。TLS 记录协议如图 14-15 所示。

3. 告警协议

告警协议用于提示何时 TLS 协议发生了错误，或者两个主机之间的会话何时终止。只有在 TLS 协议失效时告警协议才会被激活。

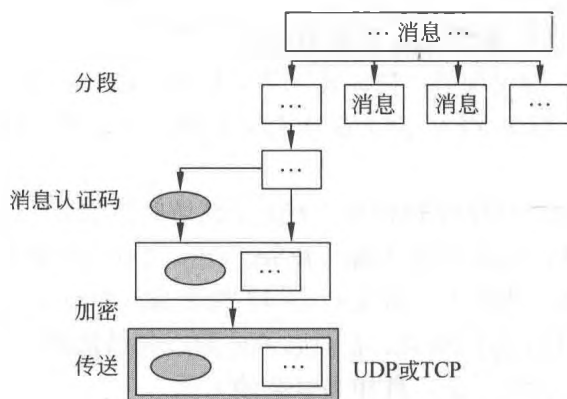


图 14-15 TLS 记录协议

14.4.3 TLS VPN 的优缺点

与其他类型的 VPN 相比, TLS VPN 有独特的优点, 归纳起来主要有如下几点。

- (1) 无须安装客户端软件。只需要标准的 Web 浏览器连接 Internet, 即可以通过网页访问企业总部的网络资源。
- (2) 适用于大多数设备。浏览器可以访问任何设备, 如可上网的 PDA 和蜂窝电话等设备。Web 已成为标准的信息交换平台, 越来越多的企业开始将 ERP、CRM、SCM 移植到 Web 上。TLS VPN 起到为 Web 应用保驾护航的作用。
- (3) 适用于大多数操作系统, 如 Windows, Macintosh, UNIX 和 Linux 等具有标准浏览器的系统。
- (4) 支持网络驱动器访问。
- (5) TLS 不需要对远程设备或网络做任何改变。
- (6) 较强的资源控制能力。基于 Web 的代理访问, 可对远程访问用户实施细粒度的资源访问控制。
- (7) 费用低且具有良好的安全性。
- (8) 可以绕过防火墙和代理服务器进行访问, 而 IPSec VPN 很难做到这一点。
- (9) TLS 加密已经内嵌在浏览器中, 无须增加额外的软件。

TLS VPN 有以下不足。

- (1) TLS VPN 的认证方式比较单一, 只能采用证书, 而且一般是单向认证。支持其他认证方式往往要进行长时间的二次开发。而 IPSec VPN 的认证方式更加灵活, 支持口令、RADIUS、令牌等认证方式。
- (2) TLS VPN 应用的局限性很大, 只适用于数据库-应用服务器-Web 服务器-浏览器这一种模式。
- (3) TLS 协议只对通信双方所使用的应用通道进行加密, 而不是对整个通道进行加密。
- (4) TLS 不能对应用层的消息进行数字签名。
- (5) LAN-to-LAN 的连接缺少理想的 TLS 解决方案。
- (6) TLS VPN 的加密级别通常不如 IPSec VPN 高。

(7) TLS 能保护由 HTTP 创建的 TCP 通道的安全，但它并不能保护 UDP 通道的安全。

(8) TLS VPN 是应用层加密，性能比较差。目前，IPSec VPN 可以达到千兆位每秒甚至接近 10Gb/s，而 TLS VPN 由于在应用层上加密，即使使用加速卡，也只能达到 300Mb/s。

(9) TLS VPN 只能进行认证和加密，不能实施访问控制。在隧道建立后，管理员对用户不能进行任何限制。而集成防火墙的 IPSec VPN 则可以根据用户的身份和角色，在其访问内部资源（主机、数据库）时进行访问控制和安全审计。

(10) TLS VPN 需要 CA 的支持，企业必须外购或自己部署一个小型的 CA 系统。对于一个企业来说，证书管理也是一件相当复杂的工作。

14.4.4 TLS VPN 的应用

目前，远程客户采用 TLS VPN 主要用于访问内部网中的一些基于 Web 的应用，这些 Web 应用目前主要有内部网页浏览、电子邮件及其他基于 Web 的查询工作。在客户与 TLS VPN 的通信中，人们通常采用 TLS Proxy 技术来提高 VPN 服务器的通信性能和安全身份验证能力。在为企业高级用户（Power User）提供远程访问及为企业提供 LAN-to-LAN 隧道连接方面，IPSec 具有无可比拟的优势。但是，人们认为典型的 TLS VPN 最适合普通员工远程访问基于 Web 的应用。虽然 TLS VPN 有很多优点，但它并不能取代 IPSec VPN，因为这两种技术分别应用在不同的领域。TLS VPN 更多考虑的是用户远程接入 Web 应用的安全性，而 IPSec VPN 主要提供 LAN-to-LAN 的隧道安全连接，它保护的是点对点之间的通信。当然，它也可以提供对 Web 应用的远程访问。目前，IPSec VPN 的厂商也开始研究如何让 IPSec VPN 兼容 TLS VPN，以增强可用性。如果能做到这点，IPSec VPN 的扩展性将大大加强，市场占有率也会更高，生命力也将更长久。

14.4.5 TLS VPN 与 IPSec VPN 比较

TLS VPN 与 IPSec VPN 的性能比较如表 14-2 所示。

表 14-2 TLS VPN 与 IPSec VPN 的性能比较

选 项	TLS VPN	IPSec VPN
身份验证	单向身份验证 双向身份验证 数字证书	双向身份验证 数字证书
加密	强加密 基于 Web 浏览器	强加密 依靠执行
全程安全性	端到端安全 从客户到资源端全程加密	网络边缘到客户端 仅对从客户到 VPN 网关之间通道加密
可访问性	适用于任何时间、任何地点访问	限制适用于已经定义好受控用户的访问
费用	低（无须任何附加客户端软件）	高（需要管理客户端软件）
安装	即插即用安装 无须任何附加的客户端软、硬件安装	通常需要长时间的配置 需要客户端软件或硬件

续表

选 项	TLS VPN	IPSec VPN
用户的易使用性	对用户非常友好，使用非常熟悉的 Web 浏览器 无须终端用户的培训	对没有相应技术的用户比较困难 需要培训
支持的应用	基于 Web 的应用 文件共享 E-mail	所有基于 IP 的服务
用户	客户、合作伙伴用户、远程用户、供应商等	更适合在企业内部使用
可伸缩性	容易配置和扩展	在服务器端容易实现自由伸缩，在客户端比较困难
穿越防火墙	可以	不可以

14.5 PPTP VPN

由 3COM 公司和微软公司合作开发的点对点隧道协议（Point-to-Point Tunneling Protocol, PPTP）是第一个用来建立 VPN 的协议。PPTP 之所以能得到广泛应用，是因为它使用起来比较灵活，容易部署，而且能得到大多数运营商的解决方案的支持。该协议最初于 1998 年提出，是 Windows NT 4.0 的一个重要组成部分。但是，此协议在提出之初存在严重的安全问题，随后在 Windows 2000 和 Windows 2003 中进行了大量的修改。即便如此，PPTP 的声誉还是由于最初的错误而受到损害。

14.5.1 PPTP 概述

PPTP VPN 最早是 Windows NT 4.0 支持的隧道协议标准，是 PPP 的扩展。PPTP 主要增强了 PPP 的认证和加密功能。PPTP 在一个已存在的 IP 连接上封装 PPP 会话，只要网络层是连通的，就可以运行 PPP。PPTP 将控制包与数据包分开，控制包采用 TCP 传输，用来进行严格的状态查询和信令信息交换；数据包部分先封装在 PPP 中，然后再封装到 GRE 协议中，用于在标准 IP 包中封装任何形式的数据包。因此，PPTP 可以支持所有的主流协议，包括 IP、IPX 和 NetBEUI 等。

PPTP 的主要功能是开通 VPN 隧道，它还是采用原来的 PPP 拨号建立网络连接。除了搭建隧道外，PPTP 对 PPP 本身没有做任何修改，只是将用户的 PPP 帧采用 GRE 封装成 IP 数据包，在 Internet 中经隧道传送。PPTP 本身并没有定义新的加密机制，它只是继承了 PPP 的认证和加密机制，包括 PAP、CHAP、MS-CHAP 身份认证机制及微软的点对点加密（Microsoft Point-to-Point Encrypt, MPPE）机制。

PPTP 是支持远程访问（Client-to-LAN）型 VPN 的一种隧道方案，它可用于移动办公或个人用户远程访问 VPN 服务器网络。同时，PPTP 也适用于企业网络之间建立 LAN-to-LAN 的 VPN 隧道连接。PPTP 在 PPP 的基础上增加了一个新的安全等级，并且

可以通过 Internet 进行多协议通信，也支持通过 Internet 建立按需的、多协议的虚拟专网。

PPTP 的两个主要任务是“封装”和“加密”。PPTP 的“封装”使用 GRE 的头部数据和 IP 头部数据包装 PPP 帧。IP 头部数据用来标识与客户机和 VPN 服务器相关的源和目的 IP 地址等路由信息。PPP 帧在 PPTP 中的数据封装方式如图 14-16 所示。从图中可以看出，PPTP 的 VPN 隧道包封装方式仅是在 PPP 帧的前面添加了一个用来标识源和目的地址的 IP 头和一个 GRE 头。

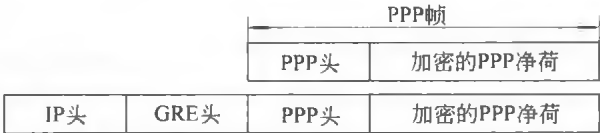


图 14-16 PPP 帧在 PPTP 中的数据封装方式

由于 PPTP 本身没有定义加密功能，因此所谓的“加密”实际上是 PPP 通过 MS-CHAP 和 EAP-TLS 协议建立会话密钥，然后再对净荷部分采用 MPPE 机制进行加密。因此，PPTP 本身不提供加密服务，只是对先前已加密的 PPP 帧进行封装。

14.5.2 PPTP VPN 的原理

点对点隧道协议由 RFC2637 定义，是一种应用比较广泛的 VPN。由于 PPTP VPN 使用了一个不安全的控制通道（该通道采用 TCP 1723 端口），且 PPTP 本身没有定义任何加密机制，因此它的安全性不如 IPSec VPN 和 TLS VPN 高。PPTP VPN 构成示意图如图 14-17 所示。

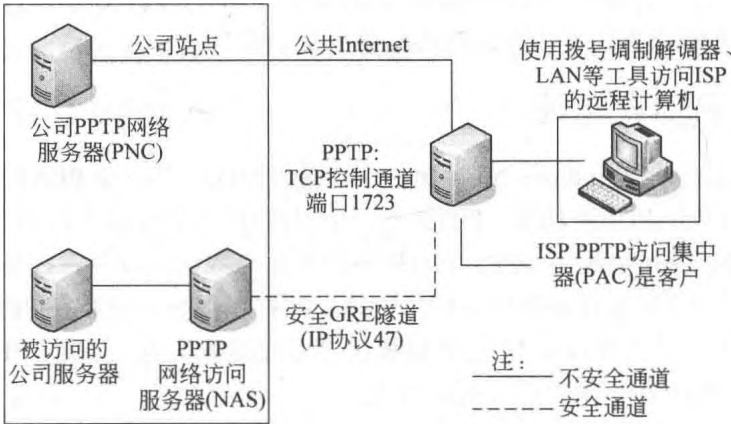


图 14-17 PPTP VPN 构成示意图

PPTP 基于 C/S 结构，它将认证和连接设置功能分离开来，而在其他类型的 VPN（如 IPSec VPN）中，这两个功能是统一的，即在同一个协议中实现了 AH 和 ESP 两个功能。PPTP 定义了 3 个功能实体：PPTP 访问集中器（PPTP Access Server，PAC）、网络访问服务器（Network Access Server，NAS，有时称做 RAS）、PPTP 网络服务器（PPTP Network Server，PNS）。

传统网络访问服务器（NAS）具有以下功能：作为 PSTN 或 ISDN 的本地接口，控

制着外部的 Modem 或终端适配器；是 PPP 链路控制协议会话的逻辑终点；是 PPP 认证协议的执行者；为 PPP 多链路由协议进行信道汇聚管理；是各种 PPP 网络控制协议的逻辑终点。PPTP 将上述功能分解成由两部分——PAC（PPTP 访问集中器）和 PNS（PPTP 网络服务器）来分别执行。这样，拨号 PPP 链路的终点就延伸至 PNS。

PPTP 正是利用了“NAS 功能分解”机制的支持，才能在 Internet 上实现 VPN。ISP 的 NAS 将执行 PPTP 中指定的 PAC 的功能。而企业 VPN 中心服务器将执行 PNS 的功能，通过 PPTP，远程用户首先拨号到本地 ISP 的 NAS，访问企业的网络和应用，而不再需要直接拨号至企业的网络，这样，由 GRE 将 PPP 报文封装成 IP 报文就可以在 PAC—PNS 之间经由 Internet 传递，即在 PAC 和 PNS 之间为用户的 PPP 会话建立一条 PPTP 隧道。

建立 PPTP 连接，首先需要建立客户端与本地 ISP 的 PPP 连接。一旦成功接入 Internet，下一步就是建立 PPTP 连接。从最顶端的 PPP 客户端、PAC 和 PNS 服务器之间开始，由已经安装好 PPTP 的 PAC 建立并管理 PPTP 任务。如果 PPP 客户端将 PPTP 添加到它的协议中，所有列出的 PPTP 通信都会在支持 PPTP 的客户端上开始与终止。由于所有通信都将在 IP 包内通过隧道，因此 PAC 只起着通过 PPP 连接进入 Internet 的入口点的作用。从技术上讲，PPP 包从 PPTP 隧道的一端传输到另一端，这种隧道对用户是完全透明的。

14.5.3 PPTP VPN 的优缺点

从 14.5.2 节的分析知，PPTP VPN 连接的思路是：先由用户通过 PPP 拨号连接到 ISP，然后通过 PPTP 在客户端和 VPN 服务器之间开通一个专用的 VPN 隧道，数据经隧道进行交换。具体做法如下。

(1) 远程 Windows 用户通过拨号网络中的远程访问服务（RAS）与本地 ISP 进行 PPP 拨号连接。

(2) 当 PPP 连接建立后，VPN 客户再使用 VPN 连接选项进行二次拨号。第二次连接不再使用与当地 ISP 连接的电话号码，而是直接使用 VPN 服务器的 WAN 适配器的 IP 地址或域名，并且客户端用 VPN 端口替代第一次电话拨号所用的 COM 端口。

从上面的分析看出，建立 PPTP VPN 如同电话拨号上网一样方便。因此，PPTP 的最大优点是：它不依赖于 TCP/IP 协议族，可以与 Novell 的 IPX 或 Microsoft 的 NetBEUI 协议一起使用。然而，由于现今的大多数网络都基于 TCP/IP，所以 PPTP 的应用具有一定的局限性。

此外，由于 PPTP 中没有定义加密功能，所以 PPTP VPN 的安全性是所有类型的 IP VPN 中最低的。因此，本书中没有把 PPTP VPN 作为讨论的重点。

14.6

MPLS VPN

MPLS VPN 是一种基于多协议标记交换（Multiprotocol Label Switching, MPLS）技术的 IP VPN。在网络路由和交换设备上应用 MPLS 技术可以简化核心路由器的路由选择方式。MPLS 利用传统路由中的标记交换技术来实现 IP 虚拟专网（IP VPN）。MPLS VPN

可用来构造宽带的 Internet 和 Extranet，它能够满足企业对业务多样性的需求。

14.6.1 MPLS 协议概述

MPLS 是基于标记的 IP 路由选择方法。用这些标记可以标识逐跳式或显式路由，并标识服务质量（QoS）、特定类型的流量（或一个特殊用户的流量）及流量的传输方式等各类信息。MPLS 采用简化技术完成第 3 层和第 2 层的转换，可为每个 IP 数据包提供一个标记。该标记与 IP 数据包一起被封装于新的 MPLS 数据包中，它决定了 IP 数据包的传输路径及优先顺序。支持 MPLS 协议的路由器会仅读取该 MPLS 数据包的包头标记，无须再去读取每个 IP 数据包中的 IP 地址等信息，即可将 IP 数据包按相应路径转发。因此，MPLS 技术可以大大加快路由器交换和转发数据包的速度。

目前的路由协议都是在一个指定源和目的地之间选择最短路径，而没有考虑该路径的带宽、载荷等链路状态，也没有绕过缺乏安全保障链路的有效方法。MPLS 技术利用显式路由选择，可灵活选择一条低延迟、高安全的路径来传输数据。

MPLS 协议实现了第 3 层路由到第 2 层交换的转换。MPLS 可以使用各种第 2 层协议。迄今，MPLS 工作组已经对帧中继、ATM、PPP 链路及 IEEE 802.3 局域网上使用的标记进行了标准化。MPLS 可为帧中继和 ATM 这些面向连接的技术提供 IP 的任意连通性。目前，MPLS 的主要发展方向在 ATM 方面，这主要是因为 ATM 具有很强的流量管理功能，能提供 QoS 服务。ATM 与 MPLS 技术相结合，能充分发挥 ATM 在流量管理和 QoS 方面的作用。标记用于转发数据包的报头，报头的格式则取决于所使用的网络。在路由器网络中，标记是单独的 32b 报头；在 ATM 网络中，标记置于虚电路标识符/虚通道标识符（VCI/VPI）信元报头中。MPLS 之所以具有很强的可扩展性，关键是因为标记只在两个通信设备之间才有特定的意义，而路由器和交换机只解读标记而不解析 IP 数据包。

IP 数据包进入网络时，边界路由器给它分配一个标记。自此，MPLS 设备就会自始至终查看这些标记信息，将这些有标记的数据包发送至其目的地。由于路由处理减少，网络的等待时间也就随之缩短，而可扩展性却有所增加。MPLS 数据包的 QoS 类型可以由 MPLS 边界路由器根据 IP 数据包的各种参数来确定，如 IP 的源地址、目的地址、端口号、TOS 值等参数。

对于到达同一目的地的 IP 数据包，可根据其 TOS 值的要求建立不同的转发路径，以确保传输质量。同时，通过对特殊路由的管理，还能有效地解决网络中的负载均衡和拥塞问题。当网络出现拥塞时，MPLS 可实时建立新的转发路由分散流量，以缓解网络拥塞。

MPLS 由 Cisco 的标记交换技术演变而来，已成为 IETF 的标准协议，是标记转发的典范。与传统的网络层技术相比，它引入了以下一些新概念。

（1）流（Flow）：从一个特定源发出的分组序列，它们被单播或多播（unicast/multicast）到特定目的地。

（2）标记（Label）：一个短且定长、物理连续、只具有局部意义的标识符，用来标识一个“流”。“局部意义”是指一个标记仅在邻接的两个 MPLS 节点之间有意义。

(3) 标记交换 (Label Swap): 一种基本的链路层转发操作, 包括查找流入分组的标记以决定对应的流出标记、封装操作、输出及其他数据处理操作。

(4) MPLS 节点 (MPLS Node): 可以用标记交换方式转发数据包的网络节点。同时, MPLS 节点还必须运行相应的 MPLS 控制协议和一定的网络层路由协议。MPLS 节点也可以选择支持传统的网络层数据包转发。

(5) 标记交换路径 (Label Switched Path, LSP): 由若干 MPLS 节点连接起来所组成的点到点的路径。在该路径上, 数据包在两 MPLS 节点之间以标记交换方式转发。

(6) MPLS 域 (MPLS Domain): 运行 MPLS 路由选择和数据包转发的一组连续节点的集合, 这些节点存在于同一个路由或管理域中。

(7) MPLS 边界节点 (MPLS Edge Node): 连接一个 MPLS 域及一个域外节点的 MPLS 节点。域外节点可以不在 MPLS 方式下运行, 也可以属于另外一个 MPLS 域。

(8) 标记交换路由器 (Label Switching Router, LSR): 核心设备。根据已计算好的交换表交换被加上标记的数据包。LSR 可以称为 MPLS 边界节点。处于边缘的设备称为边缘标记交换路由器 ELSR (Edge LSR)。边缘标记交换路由器对数据包进行初始分类处理, 并加上第一个标签。

(9) 标记分发协议 (Label Distribution Protocol, LDP): 是一系列 FSR 之间的通信规程。当在 FSRs 之间交换和转发数据包时, 该协议用来进行标记的交流及信息的传递。

14.6.2 MPLS VPN 的原理

与采用 ATM、帧中继或其他各种隧道技术建立的 VPN 相比, MPLS VPN 是一个更具吸引力的选择。传统的 VPN 采用专线技术组网, 投资大, 效率低。利用 Internet 构建 VPN, 网络的服务质量不能得到保证, 同时为保证网络安全还需投入大量资金。

在基于 MPLS 的 VPN 中, 每个 VPN 子网分配有一个标识符, 称做路由标识符 (RD), 这个标识符在服务提供商的网络中是独一无二的。RD 和用户的 IP 地址连接, 又形成转发表中一个独一无二的地址, 称为 VPN-IP 地址。

VPN 转发表中包括与 VPN-IP 地址相对应的标签。通过这个标签将数据传送到相应地点。因为标签代替了 IP 地址, 所以用户可以保持他们的专用地址结构, 无须进行网络地址转换 (NAT) 来传送数据。根据数据入口, 交换机选择一个特定的转发表, 该表中只包括在 VPN 中有效的目的地址。为了创建 Extranet, 服务提供商在 VPN 之间要明确配置可达性。

这种解决方案的优势是: 可以通过相同的网络结构支持多种 VPN, 并不需要为每一个用户建立单独的 VPN 网络连接。MPLS VPN 可以很容易地与基于 IP 的用户网络结合起来, 这种方案将 IP VPN 的能力内置于网络本身, 因此服务提供商可以为租用者配置一个网络以提供专用的 IP 网 (如 Intranet 和 Extranet) 服务, 而无须管理隧道。因为 QoS 和 MPLS 都是基于标记的技术, 所以 QoS 服务可与 MPLS VPN 无缝结合, 为每个 VPN 提供特有的业务策略。而且, MPLS VPN 用户能够使用他们专有的 IP 地址上网, 无须网络地址转换 (NAT) 的帮助。

MPLS VPN 的工作原理如下：

步骤一：网络自动生成路由表。标记分配协议（LDP）使用路由表中的信息建立相邻设备的标记值、创建标记交换路径（LSP）、预先设置与最终目的地之间的对应关系。

步骤二：将连续的网络层数据包看做“流”，MPLS 边界节点可以首先通过传统的网络层数据转发方式接收这些数据包；边缘 LSR 通过一定的标记分配策略来决定需要哪种第 3 层服务，如 QoS 或带宽管理。基于路由和策略的需求，有选择地在数据包中加入一个标记，并把它们转发出去。

步骤三：当加入标记的链路层数据包在 MPLS 域中转发时，就不再需要经过网络层的路由选择，而由标记交换路径（LSP）上的 MPLS 节点在链路层通过标记交换进行转发。LSR 读取每一个数据包的标记，并根据交换表替换一个新值，直至标记交换进行到 MPLS 边界节点。

步骤四：加入标记的链路层数据包在将要离开此 MPLS 域时，有两种情况：①MPLS 边界节点的下一跳为非 MPLS 节点，此时带有标记的链路层数据包将采用传统的网络层分组转发方法，先经过网络层的路由选择，再继续向前转发，直至到达目的节点；②MPLS 边界节点的下一跳为另一 MPLS 域的 MPLS 边界节点。此时可以采用“标记栈”（Label Stack）技术，使数据包仍然以标记交换方式进行链路层转发，进入邻接的 MPLS 域。

从上面的 MPLS 工作原理可以看出，MPLS 用最简化的技术来完成第 3 层交换向第 2 层交换的转换。采用 MPLS 技术的网络对于 IP 业务的转发，既不需要采用“逐跳方式”（Hop-by-Hop）转发，也不再需要对网络中的所有路由器进行第 3 层路由表的查询，而只需要在边缘标记交换路由器（ELSR）上做一次路由表查询，就可以给进入 MPLS 域的 IP 包打上一个标签。然后，该 IP 包在网络中仅进行第 2 层交换，快速转发到 MPLS 的目的地端，由出口 ELSR 将其恢复成传统 IP 再进行传统 IP 转发。此举加快了 MPLS 交换机查找路由表的速度，减轻了交换机的负担。由此可见，MPLS 可以满足网络高速转发 IP 包的需求，同时它也继承了 ATM 的 QoS 机制，可以满足用户对不同服务质量的要求。

14.6.3 MPLS VPN 的优缺点

MPLS 能够充分利用公用骨干网络强大的传输能力构建 VPN，它可以大大降低政府和企业建设内部专网的成本，极大地提高用户网络运营和管理的灵活性，同时能够满足用户对信息传输安全性、实时性、宽频带和方便性的需要。与其他基于 IP 的虚拟专网相比，MPLS 具有很多优点。

（1）降低了成本。MPLS 简化了 ATM 与 IP 的集成技术，使第 2 层和第 3 层技术有效地结合起来，降低了成本，保护了用户的前期投资。

（2）提高了资源利用率。由于在网内使用标签交换，企业各局域子网可以使用重复的 IP 地址，提高了 IP 资源利用率。

(3) 提高了网络速度。由于使用标签交换, 缩短了每一跳过程中搜索地址的时间及数据在网络传输中的时间, 提高了网络速度。

(4) 提高了灵活性和可扩展性。由于 MPLS 使用了“任意到任意”(Any to Any) 的连接, 提高了网络的灵活性和可扩展性。所谓灵活性, 是指用户可以制定特殊的控制策略, 以满足不同用户的特殊需求, 实现增值业务; 所谓扩容性, 是指同一网络中可以容纳的 VPN 的数目很容易得到扩充。

(5) 方便了用户。MPLS 技术将被更广泛地应用在各个运营商的网络中, 这给企业用户建立全球的 VPN 带来了极大的便利。

(6) 安全性高。采用 MPLS 作为通道机制实现透明报文传输, MPLS 的 LSP 具有与帧中继和 ATM VCC (Virtual Channel Connection, 虚通道连接) 类似的高安全性。

(7) 业务综合能力强。网络能够提供数据、语音、视频相融合的能力。

(8) MPLS 的 QoS 保证。用户可以根据自己的不同业务需求, 通过在 CE 侧的配置来赋予 MPLS VPN 不同的 QoS 等级。这种 QoS 技术既能保证网络的服务质量, 又能减少用户的费用。

(9) 适用于城域网 (PAN) 这样的网络环境。另外, 有些大型企业分支机构众多, 业务类型多样, 业务流向流量不确定, 也特别适合使用 MPLS。

MPLS VPN 既具有交换机的高速度与流量控制能力, 又具备路由器的灵活性; 能够与 IP/ATM 很好地结合, 使 ATM 设备的投资得到充分利用。MPLS 技术将交换机与路由器的优点完美地结合在一起。

但是, MPLS 技术也存在明显的不足:

(1) 由于 ATM 技术本身目前备受争议, 所以 MPLS VPN 的存在价值大打折扣。

(2) MPLS VPN 与 IP-in-IP VPN、PPTP VPN 一样, 本身没有采用加密机制, 因此 MPLS VPN 实际上并不十分安全。

总之, IPSec VPN 是最安全的协议, 其安全性优于其他类型的 VPN。IPSec 与 L2TP 和 MPLS 并不相互排斥, 而是可以结合使用的。在基于 L2TP 或 MPLS 构建 VPN 时, 如果需要“绝对”的安全保障, 则可以与 IPSec 结合使用。

除了以上讨论的各种类型的 VPN 之外, 还有许多其他类型的 VPN。例如, 在 RFC2003 中还定义了一种“IP 中的 IP (IP-in-IP)”隧道技术。它常被看做 NAT 技术的一种变形。IP-in-IP VPN 被单独使用时, 不提供任何加密和认证。

最后必须强调的是: 安全问题是一个系统问题, 不仅取决于 VPN 的这些隧道协议自身的安全性, 还取决于网络中采用的其他技术和设备的安全性, 以及所采用的物理安全措施。

通过本章的学习, 要求读者掌握 VPN 的基本概念和分类, 了解构建 VPN 的各种隧道协议, 掌握 IPSec VPN、TLS VPN、PPTP VPN 和 MPLS VPN 的概念、工作原理和优缺点。IPSec VPN 既适合于构建 LAN-to-LAN 型的 VPN 连接, 也适合于构建 Client-LAN 型的 VPN 连接; TLS VPN 和 PPTP VPN 则仅支持 Client-LAN 型的 VPN 连接; MPLS VPN 适用于用户数量众多、流量很大、媒体格式多样的城域网应用, 它也可以与 IPSec VPN

结合起来使用，以获得更高的安全性。在实际应用中，究竟选择何种类型的 VPN，需要根据企业或组织的安全策略和安全需求而定。希望读者能将本章学到的知识运用到实践中去。

习 题

一、填空题

1. 根据访问方式的不同，VPN 可以分为_____和_____两种类型。
2. VPN 的关键技术包括_____、_____、_____、_____和_____等。
3. 第 2 层隧道协议主要有_____、_____和_____3 个协议。
4. 第 3 层隧道协议主要有_____、_____和_____3 个协议。
5. IPSec 的主要功能是实现加密、认证和密钥交换，这 3 个功能分别由_____、_____和_____3 个协议来实现。
6. IPSec VPN 主要由_____、_____、_____、_____和_____5 个模块组成。
7. IPSec 在 OSI 参考模型的_____层提供安全性。
A. 应用 B. 传输 C. 网络 D. 数据链路
8. ISAKMP/Oakley 与_____相关。
A. SSL B. SET C. SHTTP D. IPSec
9. IPSec 中的加密是由_____完成的。
A. AH B. TCP/IP C. IKE D. ESP
10. 在_____情况下，IP 头才需要加密。
A. 信道模式 B. 传输模式
C. 信道模式和传输模式 D. 无模式

二、思考题

1. 如何理解虚拟专用网络中的“虚拟”和“专用”？
2. 什么是 VPN？一个好的 VPN 应具备哪些特点？
3. VPN 的安全性因素有哪些？
4. IPSec 有哪两种工作模式？如何通过数据包格式区分这两种工作模式？
5. 在有 IPSec 保护的 IP 数据报中，“认证头”（AH）起什么作用？
6. 请解释一下 AH 和 ESP 协议。
7. IPSec 和 IKE 的关系是什么？
8. 简述 TLS VPN 的工作原理，并指出其优缺点。
9. 简述 PPTP VPN 的工作原理，并指出其优缺点。
10. 简述 MPLS VPN 的工作原理，并指出其优缺点。
11. 请制作一个表格，详细比较 IPSec VPN、SSL VPN、PPTP VPN 和 MPLS VPN 的

功能特点。

12. 你认为 IPSec VPN 能代替 SSL VPN 吗？SSL VPN 能代替 IPSec VPN 吗？为什么？
13. 画出各类 VPN 在网络拓扑图中所处的位置。
14. 尝试通过阅读文档，熟悉、配置 Linux 操作系统下的 VPN 工具——FreeSWAN。